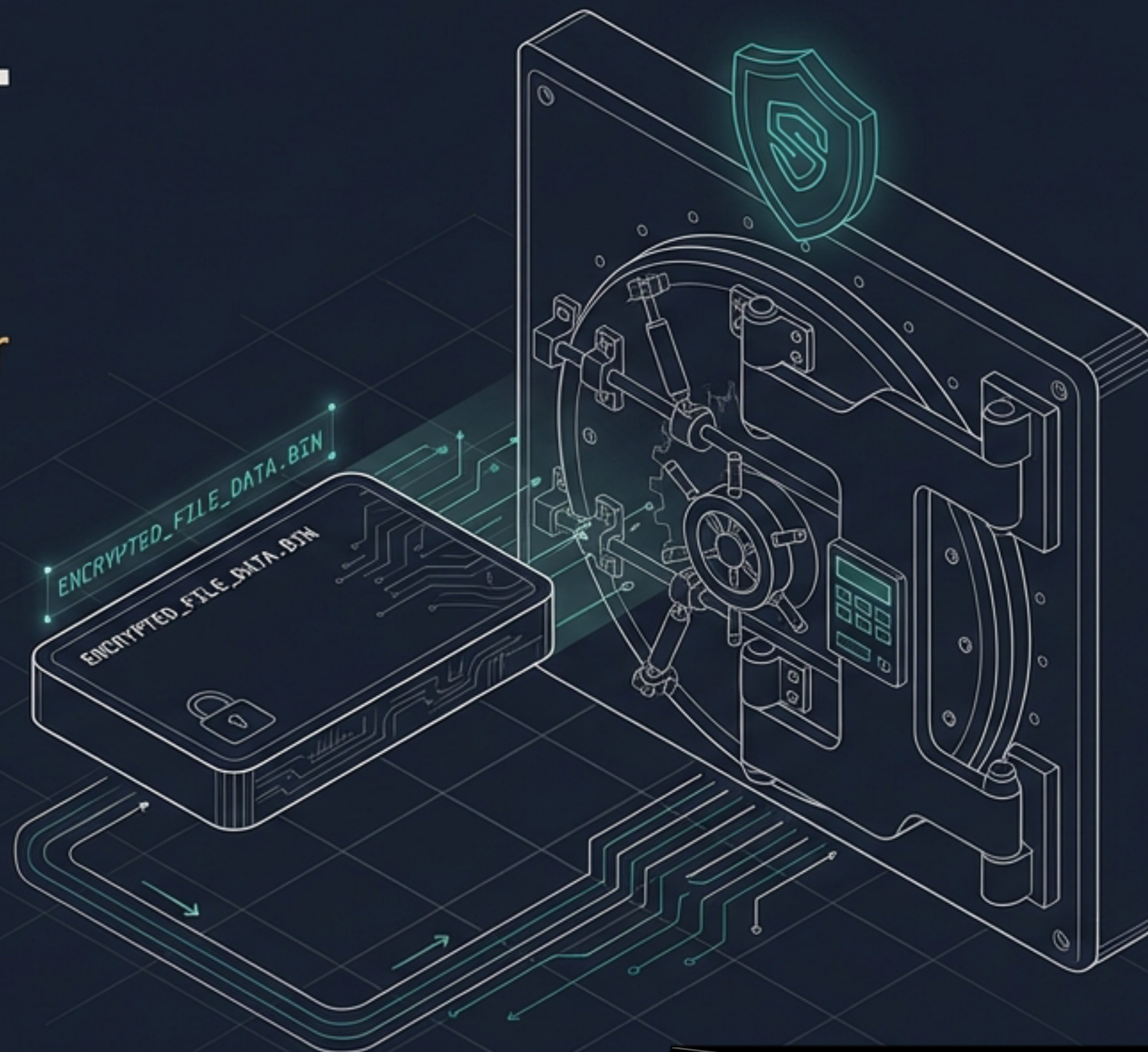


APPSEC THREAT MODEL

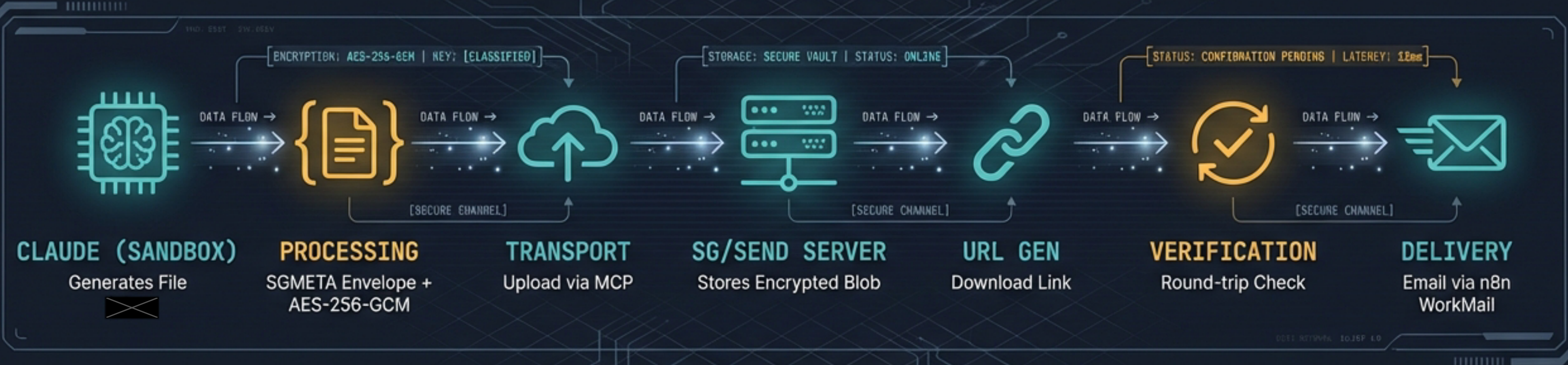
SG/Send Encrypted File Transfer



VERSION:	v0.7.1
DATE:	26 Feb 2026
FROM:	AppSec
TO:	Architect, Developer, GRC, DPO, Conductor

Review of v0.7.1 Workflow | Symmetric vs PKI Architectures

THE SCOPE: A SINGLE PIPELINE, TWO TWO OUTCOMES



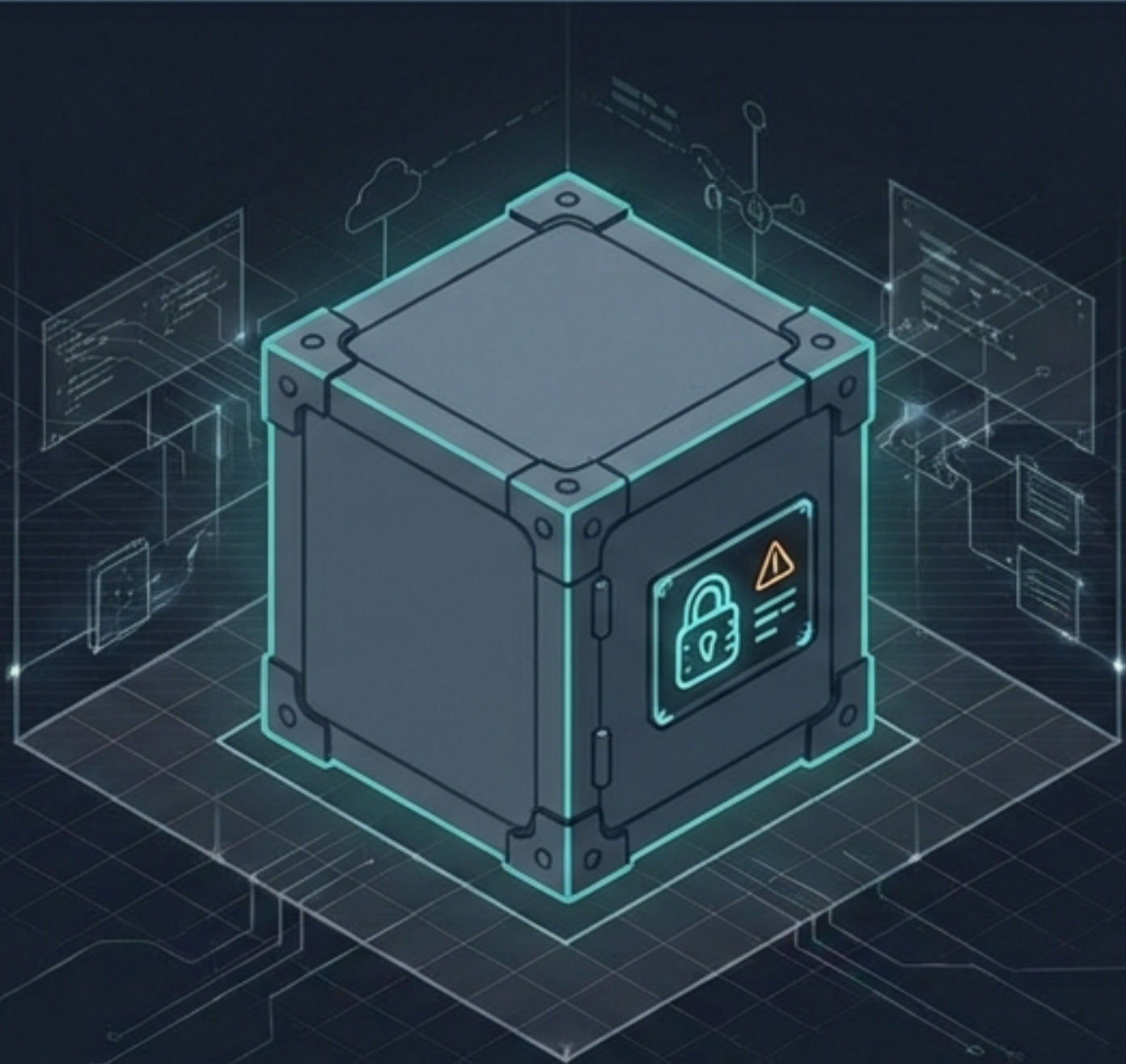
CONTEXT: THIS REVIEW COVERS TWO DISTINCT MODES—SYMMETRIC AND PKI—BECAUSE THEIR THREAT PROFILES ARE FUNDAMENTALLY DIFFERENT.

CORE CONCEPT: ZERO KNOWLEDGE STORAGE



**WHAT SG/SEND KNOWS:
NOTHING.**

THE SERVER HOLDS ONLY
ENCRYPTED BLOBS AND
OPAQUE TRANSFER IDS.



THE GUARANTEE:

EVEN IF THE SERVER IS
FULLY BREACHED (THREAT
T-004), THE ATTACKER
GAINS ONLY CIPHERTEXT.

THE SERVER HAS THE SAFE, BUT NEVER THE KEY.



A TALE OF TWO PATHS

MODE A: SYMMETRIC



The Key is in the URL.
Convenient, but the URL is a secret.

MODE B: PKI



The Key is the Recipient.
Friction, but the URL is just a reference.

The mechanism of delivery changes the threat profile entirely.

MODE A (SYMMETRIC): THE URL IS THE SECRET

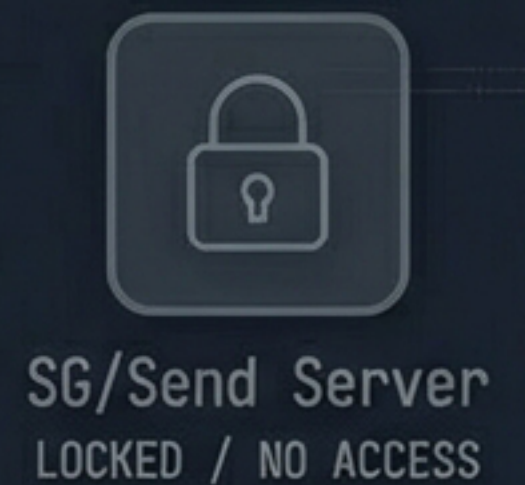
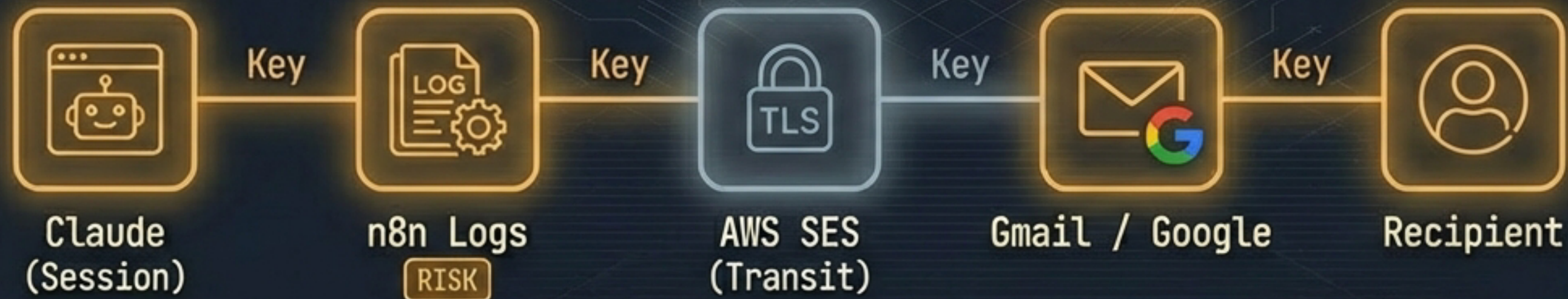


↑
DECRYPTION KEY

- ⚠ **Decryption:** Anyone with the full URL can decrypt.
- 🛡 **Revocation:** Requires deleting the transfer entirely.
- ⚠ **Replay Attack:** Possible until expiry or deletion.

⚠ **SENSITIVITY: HIGH.** The key travels with every share.

MODE A AUDIT: THE CHAIN OF CUSTODY

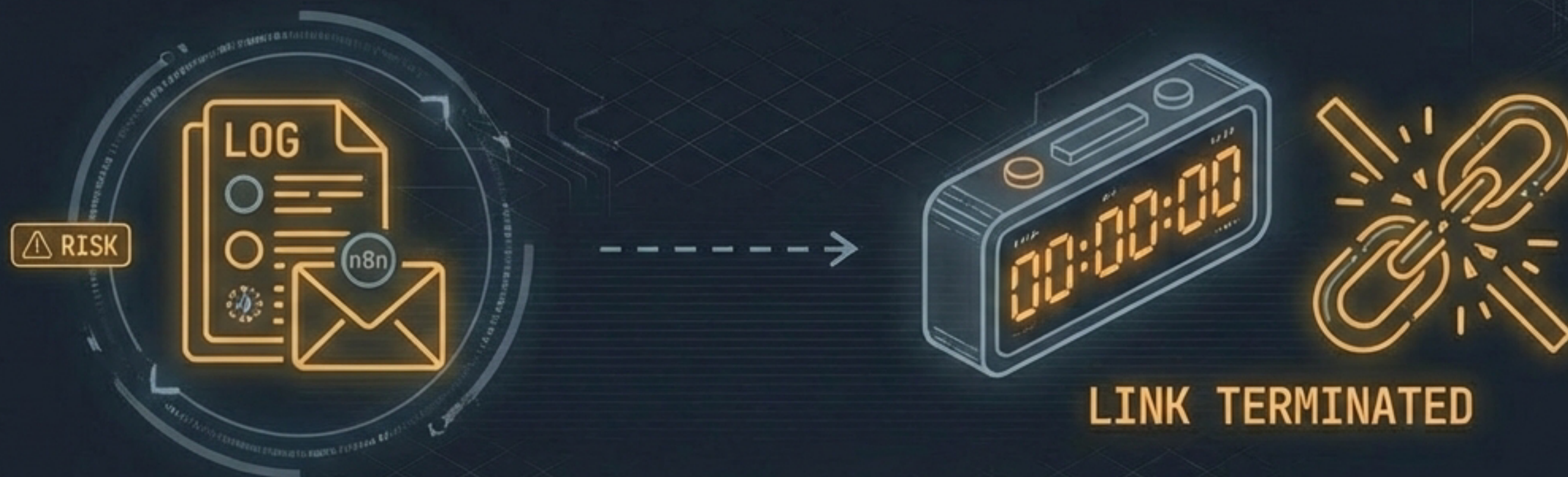


- ⚠️ **Claude: Yes** (Key in context)
- ⚠️ **n8n Logs: Yes** (Risk: Full URL often logged)
- ⚠️ **Gmail: Yes** (Google has access to email body)
- 🛡️ **SG/Send Server: NO** (Zero knowledge preserved)

A long chain of access. Mitigated by TLS, but the exposure exists.

MITIGATION: ONE-TIME USE

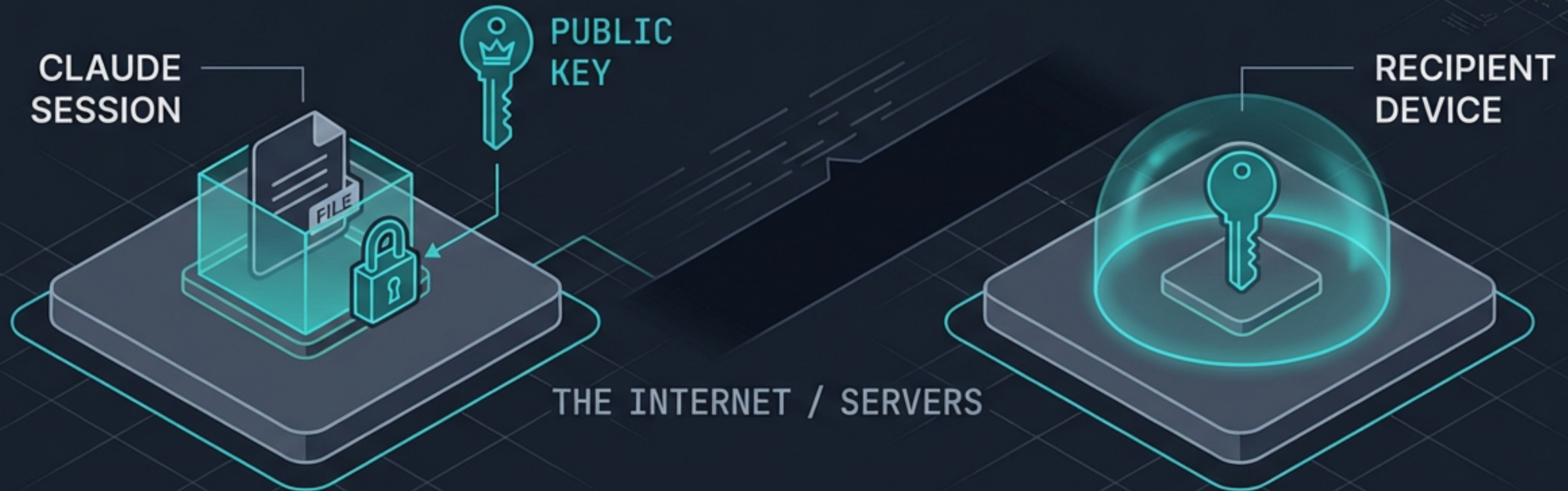
Turning 'Persistent Exposure' into 'Narrow Time Window'



- **Strategy:** The link dies after the first download.
- **Short Expiry:** 24-hour default death clock.
- **Result:** The n8n log and Gmail history become worthless artifacts.

"If the link is dead, the logs don't matter."

MODE B (PKI): ENCRYPTION AT SOURCE



- Public Key: Encrypts content within the Claude session.
- Private Key: Held only by the recipient's browser.
- The Difference: The key never travels.



MODE B AUDIT:

THE BROKEN CHAIN OF ACCESS



ANALYSIS

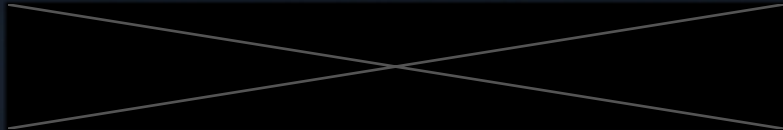
- n8n/Gmail: See only an opaque URL reference.
- Claude: Encrypts but cannot decrypt (once session clears).

VERDICT: The chain of custody remains,
but the chain of *access* is broken.

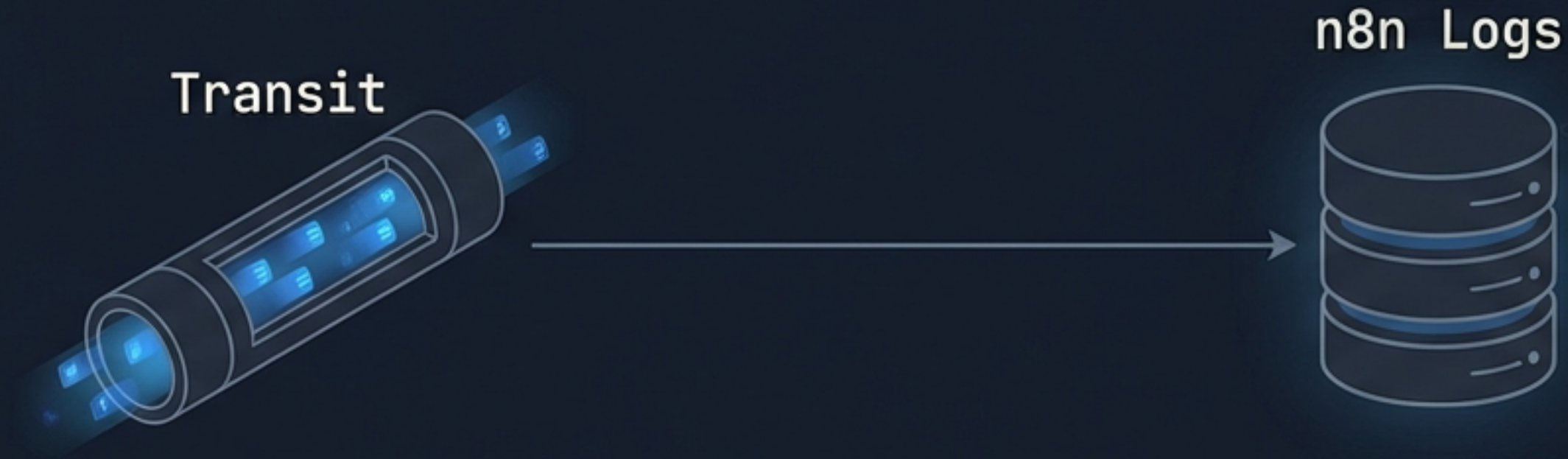
Architecture Comparison

Feature	Mode A (Symmetric)	Mode B (PKI)
Sender Verification	None	Yes (Signed with Private Key)
URL Sensitivity	High (Secret)	Low (Reference)
Server Knowledge	Zero	Zero

Key Takeaway: PKI enables proof of authorship—the recipient knows who sent it and that it wasn't forged.



THREAT ANALYSIS: TRANSIT & INFRASTRUCTURE



T-001 URL Interception

Mode A Impact: High (Data Compromise)

Mode B Impact: None

T-002 n8n Log Exfiltration

Risk: Attackers reading internal logs.

Mitigation (P0): Configure n8n to truncate logs/not log full request bodies.

Threat Analysis: Source & Server



Source (Claude)

T-003 Claude Context

Risk is ephemeral. Session window clears.
Status: Accepted Risk.



Server (SG/Send)

T-004 Server Breach

The Zero-Knowledge Shield.
A breach yields no data.

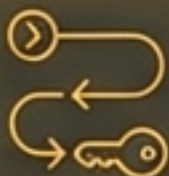
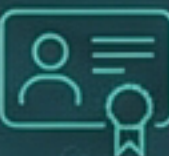
"Our architecture assumes the server will be breached.
Zero-knowledge preserves security."

RESIDUAL RISK MATRIX (WITH MITIGATIONS)



ANALYSIS: Mitigations bring the profile within acceptable limits, but Mode A retains dependency on Gmail security.

Recommendations & Roadmap

PRIORITY		[P0] IMMEDIATE: Configure n8n to not log full request bodies (DevOps).
		[P0] IMMEDIATE: Enforce One-Time Use on all symmetric transfers (Dev).
		[P1] HIGH: Short expiry (24h) default.
		[P1] HIGH: The Upgrade Path: Build user nudges toward PKI.
		[P3] FUTURE: Implement signed sender identity.

Final Verdict

Symmetric Mode is a secure courier.
PKI Mode is a teleportation device.

We support the former for convenience,
but we build for the latter for security.